BurpSuite: The Basics

The Industry Standard Framework for Web Application Security

Burp Suite is a Java-based framework that serves as the industry-standard tool for web application penetration testing. This module introduces the fundamental mechanics of capturing and manipulating **HTTP/HTTPS traffic** between a browser and a web server. We explore the distinct editions—**Community, Professional, and Enterprise**—and dive into the core feature set, including the **Proxy, Repeater, Intruder, and Decoder**.
The content provides step-by-step guidance on configuring connectivity via **FoxyProxy**, managing project **Scope**, and handling **SSL/TLS certificates** for HTTPS interception. By mastering these basics, security professionals can effectively bypass client-side restrictions and perform manual vulnerability assessments with precision.

This **documentation** and **learning approach** is strongly inspired by the structured, hands-on content provided by TryHackMe, which significantly contributed to practical understanding of "BurpSuite Basic" concepts.

WEIRDO

DOCUMENTED BY

Kaustubh Ghosalkar aka "WEIRDO"

LINKEDIN

GITHUB

1. What is Burp Suite?

Burp Suite acts as an intermediary (proxy) between your web browser and the target server. It allows you to pause, view, and modify data before it is sent or received.

Edition Comparison

Edition	Use Case	Key Features
Community	Beginners / Open Source	Manual tools (Proxy, Repeater), no automated scanner.
Professional	Professional Pentesters	Automated scanner, no rate limits, save projects.
Enterprise	Large Organizations	Continuous server-based scanning, CI/CD integration.

2. The Burp Suite Toolset

Burp is not just one tool, but a suite of modules designed for different stages of an attack.

- **Proxy:** The heart of Burp. Intercepts and modifies requests.
- **Repeater:** Manually resends specific requests to test for vulnerabilities like SQLi.
- **Intruder:** Used for automated attacks like brute-forcing login forms or fuzzing.
- **Decoder:** Converts data between formats (e.g., URL, Base64, Hex).
- **Comparer:** Highlights the differences between two similar requests or responses.
- **BApp Store:** An extension marketplace to add third-party features.

3. Setup and Connectivity

To analyze traffic, you must route your browser through Burp Suite (defaulting to **127.0.0.1:8080**).

FoxyProxy Configuration

FoxyProxy is a browser extension that simplifies switching proxies. To connect:

1. **IP:** Set to 127.0.0.1.
2. **Port:** Set to 8080.
3. **Activate:** Select the Burp profile in the extension.

The Burp Browser

Burp includes a pre-configured **Chromium browser**. This eliminates the need for manual proxy or certificate setup.

- **Access:** Proxy Tab -> Open Browser.
- **Tip:** If running as root (Linux), enable "Allow Burp's browser to run without a sandbox" in settings.

WEIRDO

4. Navigation and Dashboard

The Burp UI is divided into modules (top bar) and sub-tabs (secondary bar).

Keyboard Shortcuts

Shortcut	Action
Ctrl + Shift + D	Switch to **Dashboard**
Ctrl + Shift + P	Switch to **Proxy**
Ctrl + Shift + R	Switch to **Repeater**
Ctrl + U	**URL Encode** selected text

The Dashboard Quadrants

1. **Tasks:** Background activities like passive crawling.
2. **Event Log:** Status updates (e.g., "Proxy started on 8080").
3. **Issue Activity:** (Pro Only) Vulnerability scanner findings.
4. **Advisory:** (Pro Only) Remediation details for found issues.

5. Site Map and Scoping

As you browse, Burp builds a **Site Map** in the **Target** tab.

- **Scope Settings:** Crucial for "noise" reduction. By adding a target to the scope, you can tell Burp to ignore background traffic (like Google analytics or Windows updates).
- **Benefit:** Ensures you don't accidentally attack out-of-scope systems, which could be a legal risk.

6. Proxying HTTPS Traffic

Browsers naturally distrust Burp Suite when it intercepts encrypted HTTPS traffic. To fix this, you must install the **PortSwigger CA Certificate**.

Command Section: Certificate Installation

1. **Download:** Visit http://burp/cert while the proxy is active.
2. **Import:** In Firefox, go to Settings -> View Certificates -> Import.
3. **Trust:** Check "Trust this CA to identify websites."

WEIRDO

7. Practical Example: Bypassing Client-Side Filters

Client-side filters (like HTML field limits) are easily bypassed because the user controls the data before it hits the server.

Example: Reflective XSS

1. **The Target:** A form that blocks special characters like < or >.
2. **The Intercept:** Enter "test@email.com" in the browser and hit Submit.
3. **The Manipulation:** In Burp Proxy, change the email value to <script>alert("XSS")</script>.
4. **The Result:** The server processes the malicious payload because the browser's filter was bypassed.

Conclusion and Cheatsheet

Conclusion

Burp Suite is the foundational tool for any web penetration tester. By acting as a transparent proxy, it grants complete visibility into the communication between client and server. Mastery of the **Proxy** for interception and the **Target** tab for scoping ensures a clean, professional testing environment. While the Community Edition lacks automated scanning, its manual capabilities are sufficient to discover complex vulnerabilities like **XSS, SQLi, and IDOR**.

Fast Revision Cheatsheet

- **Proxy Address:** 127.0.0.1:8080.
- **Intercept On:** Pauses the request so you can edit it.
- **Repeater:** Capture, Modify, Replay.
- **Intruder:** Brute-force / Fuzzing.
- **Decoder:** Quick encoding/decoding of payloads.
- **CA Certificate:** Required to see HTTPS traffic (cacert.der).
- **Scope:** Limits Burp's focus to your specific target IP/Domain.
- **FoxyProxy:** Recommended Firefox extension for proxy switching.